

EternalBlack — Internal Document

CONFIDENTIAL — SIMULATION OSINT FICTIVE — eternalblack.fr

Sentinex IAM — IR-2025-091 incident post-mortem (PRIVILEGED & CONFIDENTIAL)

Document kind: incident

Entity: Sentinex IAM Ltd — Ireland

Registration: IE-CRO-712334

Domain: sentinex.io

Address: Block C, Grand Canal Plaza, Dublin 2, D02 RX08

Directors: Niamh O'Sullivan, Cillian Doherty

Owner reference: BlackVortex (user id 1)

Contact email: blackvortex@guardpost.io

Payment wallet BTC: bc1qxf9v2e7k3rtn4ydp8cg6l5a2qwzj8fhp7m3k2u

Incident Post-Mortem — IR-2025-091 (PRIVILEGED & CONFIDENTIAL — prepared at the direction of counsel)

Incident ID : IR-2025-091

Severity : Sev-1 (data exfiltration, customer-impacting)

First malicious act : 2026-02-26 14:11 UTC

Detection : 2026-03-04 09:47 UTC (138 hours dwell time)

Containment : 2026-03-04 16:22 UTC

External notification: 2026-03-09 (DPC Ireland, ENISA), customers TBD pending counsel

Lead responder : Cillian Doherty (CTO), with Hetherington Stratford IR (retained 2026-03-04)

1. Executive summary

On 2026-02-25 at 22:08 UTC a Sentinex platform engineer (employee #047, hereafter 'Subject A') accepted a sequence of 14 push-MFA prompts after a malicious actor triggered an Okta-clone authentication portal hosted at [https://sentinex-auth.iam-portal\[.\]net](https://sentinex-auth.iam-portal[.]net) (registered 2026-02-19, IONOS, Cloudflare-fronted, no longer resolving). The actor obtained Subject A's federated session and pivoted to the Krios managed-Postgres console using a long-lived break-glass token (token id `krios-bg-04`) that had been provisioned during a 2025-08 disaster-recovery drill and was never rotated. The break-glass token was scoped to read the warm-standby snapshot bucket (`s3://sentinex-krios-warmstandby/`), which is exactly what the actor exfiltrated.

2. Kill-chain timeline (UTC)

2026-02-19 11:02 Attacker domain `sentinex-auth.iam-portal[.]net` registered.
2026-02-25 21:53 Subject A receives spear-phish (subject: 'Pending SSO migration').
Sender: it-support@sentinex.io.support[.]ms-relay[.]net (homograph).
2026-02-25 22:08 Subject A clicks, types creds on the clone, accepts 14 push prompts.
2026-02-25 22:11 Actor establishes Okta-equivalent session, region: eu-west-1.
2026-02-26 14:11 Actor authenticates to Krios console as Subject A; enumerates snapshots.
2026-02-26 14:38 `aws s3 cp` exfil begins from a Tor-fronted vps (185.220.101.45 → ...).
2026-03-04 04:20 Exfil concluded (~412 GB compressed).
2026-03-04 09:47 AWS GuardDuty 'BackdoorMultiplePorts' alert triggers; SOC engaged.
2026-03-04 16:22 Containment achieved — break-glass tokens revoked, Subject A's SSO quarantined, all federated assertion-signing keys rotated.

3. Root cause

Primary : Break-glass token `krios-bg-04` was scoped over-broadly (granted SnapshotRead on `\*` rather than per-tenant) and lacked a rotation policy. This was raised internally in IR-2025-066 (audit-trail-token sprawl review, 2025-08-12, owner c.doherty@sentinex.io) with remediation target 2026-Q1. The remediation was reprioritised behind Series B dataroom prep.

Secondary: Push-MFA without number-matching. WebAuthn rollout for platform engineers was scoped for 2026-Q2 (commit `b7e2c0a`, dated 2025-11-04).

Tertiary : Subject A's onboarding ran without the standard phishing-resistance module (training-id PR-101) — the LMS marked it 'completed' against an invalidated SAML assertion in 2024-Q4; never re-issued.

4. What was taken (confirmed)

- Identity DB snapshot 2026-02-25T04:00Z (1,842,006 rows across 3,214 tenants).
- Investor dataroom — `SNX-DR-2025-IM-04` (the Series B memorandum) + Annex C tenant map.
- 412 customer support transcripts (Q1 2026, redacted internally).
- Slack export `general` and `incident-response-priv` (2024-2026, ~38k messages).
- HelvetiaPay's outbound webhook signing key (rotated 2026-03-04 17:01).

5. Customer notification posture (counsel input pending)

Walsh Lawless LLP (e.o'farrell@walshlawless.ie) advises selective notification to the top 50 federated tenants ahead of any public statement, based on contractual ENS clauses. The DPC Ireland 72-hour window was met (notification filed 2026-03-09 08:00). Outside counsel raises significant exposure under HelvetiaPay's MSA §11.3 indemnity (uncapped for security breach causing regulatory action). Estimate EUR 4.2-9.7 M.

6. Communication discipline

All Sentinex employees must route any external mention through brendan@walshlawless.ie pending counsel approval. Internal Slack channel `incident-response-priv` is the only authorised forum for substantive discussion. This memo is privileged work product — do not forward, do not print, do not summarise in non-privileged channels.

-- end of document --